## (一) 摘要

隨著網際網路協定快速演進，HTTP/3 (基於 QUIC 協定) 已然成為新一代傳輸標準，被 Google、Facebook 等網站廣泛採用。然而，HTTP/3 採用基於 UDP 的傳輸層與強制 TLS 1.3 加密機制，導致傳統基於特徵碼 (Signature-based) 與深度封包檢測 (DPI) 的防火牆完全失效。而惡意攻擊者更可進一步利用此特性，透過封包切割與時序干擾等對抗式規避技術 (Adversarial Evasion) ，並偽裝成正常流量以繞過現有的流量分析系統。此外，真實網路環境中攻擊手法日新月異，標記惡意流量成本極高且難以即時更新，使得傳統監督式學習模型難以面對零時差攻擊 (Zero-day Attack)。

針對上述挑戰，我們你研究整合了威脅情資 (Cyber Threat Intelligence, CTI) 、非監督式深度學習與資安事件自動化回應，在不完整解密封包的前提下，精準識別並阻斷隱蔽的惡意 QUIC 流量。系統架構分為三個部份，第一部份為情資過濾，透過串接自建的 MISP (Malware Information Sharing Platform) 平台，優先阻斷已知的惡意來源，大幅降低電腦運算負載；第二部份為行為異常偵測，透過深度學習 (Deep Learning) 進行非監督式學習。模型僅需學習正常 HTTP/3 流量的部份特徵，包含封包長度、封包序列與到達時間間隔。當遭遇經過偽裝的對抗式攻擊流量時，因為其時序行為偏離正常基準，將產生高重構誤差 (Reconstruction Error)，進而被判定為異常；第三部份為自動化回應，當第二部份偵測到異常，系統將透過資安協作自動化應變 (Security orchestration, automation and response, SOAR) 機制自動下發防火牆阻斷規則，並將新的威脅指標 (IoC) 回饋至 MISP 情資庫。本研究將利用虛擬機與 aioquic 建置高擬真攻防實驗場域，驗證在面對各類變形攻擊時的韌性與自動化防禦效率，為後量子時代的加密網路安全提供具前瞻性的解決方案。

## (二) 研究動機與研究問題

因為協定典範轉移帶來的防禦真空，網際網路正面臨從 TCP/TLS (HTTP/1.1, HTTP/2) 轉向成 UDP/QUIC (HTTP/3) 的變革。QUIC 協定雖然大幅提升了傳輸效能與降低延遲，但因其預設全加密與連線遷移 (Connection Migration) 特性，卻成為資訊安全的雙面刃。過去傳統的網路安全設備（如 IDS/IPS、WAF）大多是針對 TCP 設計，然而面對封裝在 UDP 內的 QUIC 加密流量，往往陷入不知所措的困境。這使得 HTTP/3 極易成為惡意軟體、勒索病毒與殭屍網路進行命令控制與資料外洩的隱蔽通道。而對抗式攻擊與偽裝技術的泛濫，使得當前的資訊安全研究多集中於使用機器學習進行流量分類，但忽略了攻擊者也在演進的事實。駭客已開始採用對抗式機器學習概念，透過微調封包大小或故意延遲發送，改變

流量的統計特徵。這種能輕易騙過訓練資料單一的傳統 AI 模型。若防禦系統無法具備強健性將形同虛設。

過去標記數據的稀缺與維護效率的挑戰在學術研究中，往往假設擁有標記完美的「良性」與「惡意」資料集。然而在真實的企業資安維運中，攻擊手法變幻莫測，要蒐集並且標記大量的最新攻擊樣本是不切實際的 (Labeling is expensive)。此外面對層出不窮的警告，資安人員往往面臨告警疲勞，導致回應速度過慢。因此，如何利用「非監督式學習」來偵測未知威脅，並結合自動化回應機制來實現防禦，是目前資安領域待解決的關鍵課題。

基於上述動機，在這次計畫中，我們針對以下問題進行研究與探討：

1. 在不解密的情況下，提取 HTTP/3 加密流量的有效指紋。
2. 克服對抗式樣本 (Adversarial Examples) 對偵測模型的干擾。
3. 在缺乏惡意標記數據的環境下，實現對未知威脅的偵測。
4. 整合情資過濾系統，對每筆流量做初始化過濾。
5. 結合 SOAR，針對異常自動化建立威脅和事件的回應

# (三) 文獻回顧與探討

## 5.1 生成對抗網絡 (GAN) 在網絡異常檢測中的未來

傳統的異常檢測技術在面對現代網絡威脅時存在明顯局限，包括：依賴預先存在的攻擊特徵知識、無法有效應對 zero-day、數據集極度不平衡，以及難以適應高維度和複雜的數據分佈。而 GAN 作為一種強大的非監督式深度學習模型，透過生成器 (Generator) 與判別器 (Discriminator) 的對抗博弈。

論文 [1] 評估了多種最先進的 GAN 模型如何應對特定挑戰：

依賴先驗知識與未知攻擊： ACGAN 和 N-GAN 減少了對歷史特徵的依賴。N-GAN 通過引入少量惡意樣本進行弱監督學習，提升了對未知攻擊類型的檢測能力。

資源消耗與實時性：針對深度學習高運算量的問題，BiGAN、FID-GAN 和 GANAD 優化了架構。FID-GAN 專為 Fog Computing 設計，通過編碼器加速潛在空間映射，顯著降低了延遲，適合實時檢測；而 GANAD 未解決不穩定性能，採用類似的自編碼器架構以縮短模型訓練時間。

數據不平衡：FlowGAN、IGAN-IDS 和 GAN-SR 等模型專注於生成少數類 (攻擊) 樣本。實驗顯示，FlowGAN 在不平衡數據集上的表現優於傳統採樣方法，顯著提升了召回率。

複雜數據與即時數據：ALAD 和 RCALAD 都利用循環一致性 (Cycle Consistency) 和多重判別器來處理複雜的高維網絡數據，並且在 KDDCup99 數據集上展現了高精確度。

## 5.2 基於深度卷積生成對抗網路的半監督加密流量分類

隨著網際網路加密協定 (如 QUIC、TLS 1.3) 的普及，傳統基於連接埠或深度封包檢測 (DPI) 的分類方法逐漸失效。雖然深度學習技術在領域中展現出級大的潛力，但因依賴大量標註數據，且在加密流量環境中，獲取大規模且準確的標註數據極為困難且成本高昂。

Auwal 和 Huifang [2] 提出了一種使用深度卷積生成對抗網路 (DCGAN) 的半監督學習方法，在利用少量標註數據與大量未標註數據來訓練分類器。並選用了三個具備時間序列特性且不受加密影響的特徵：封包長度、封包方向、封包到達間隔時間 (Inter-arrival time) 。作者認為 TCP 視窗大小等特徵受網路速度影響較大，故未採用。

研究結果顯示「封包方向」是對分類準確度影響最大的單一特徵，但結合其於兩個特徵能達到最佳效果。另根據調整 PIM 的序列長度，發現設定為 20 個封包是效能與準確率最合理的選擇。

## 5.3 FlowGAN：基於生成對抗網路的動態交通特徵偽裝

隨著深度封包檢測 (DPI) 的進步，互聯網已能利用網站指紋 (Website Fingerprinting, WF) 與協議指紋 (Protocol Fingerprinting, PF) ，透過分析加密流量的統計特徵來識別並封鎖匿名通訊工具。傳統防禦手段如流量填充 (Padding) 或基於規則的流量變形 (Traffic Morphing) ，往往因模式固定、開銷過大或依賴特定宿主服務而難以應對動態變化的審查環境。

針對上述，Jie 等學者 [3] 提出了 FlowGAN，將生成對抗網絡 (GAN) 應用於網絡流量偽裝的系統。該系統的核心思想是利用 Wasserstein GAN (WGAN) 讓生成器自動學習合法「目標流量」的高維統計分佈 (如封包大小、方向、時間間隔) 。接著利用基於 CUMUL 的流量生成算法，將被審查的「源流量」 (Source Flow) 動態整形，使其特徵分佈與目標流量趨於一致。

## 5.4 HTTP/3 (QUIC) 流量分析與加密流量分類

QUIC 協議作為 HTTP/3 的傳輸層基礎，正迅速取代傳統的 TCP+TLS 組合。而 QUIC 對網路監控帶來了許多挑戰，因為它不僅加密了 payload，還會對連線握手（handshake）封包進行了混淆，導致傳統依賴明文 Server Name Indication (SNI) 的深度封包檢測失效。目前針對 QUIC 的細粒度服務分類研究仍處於起步階段，缺乏大規模的真實流量評估。

研究 [4] 評估並比較了三種分類模型：

Multi-modal CNN (mm-CNN) ：一種深度學習模型，能同時處理封包元數據序列（packet metadata sequences）與流統計特徵（flow statistics）。

LightGBM：基於梯度的決策樹集成模型，並且主要依賴流統計特徵。

IP-based classifier： 基於 IP 位址的傳統分類方法，作為基準線（baseline）。

該研究並證實了 QUIC 流量分類的可行性，但也揭示了如果過度過度依賴握手階段的特徵（如憑證大小）可能導致模型在真實環境中快速失效。

## (四) 研究方法及步驟

本研究擬在建構一套針對 HTTP/3 (QUIC) 加密流量進行深度檢測與自動化阻斷，有別於傳統基於規則的防火牆，本系統採用混合式防禦架構，結合威脅情資（CTI）與非監督式深度學習（Unsupervised Learning）的深度，並透過自動化編排與回應（SOAR）機制實現防禦閉環。另有鑑於 QUIC 協定涉及底層 UDP 傳輸與核心路由控制，為確保實驗環境具備真實作業系統的網路行為且便於重現，我們將使用虛擬機建置封閉攻防演練環境。

系統架構共分為三格主要模組：

1. 預過濾模組：作為第一道防線，負責解析進入閘道器的 QUIC 封包標頭，提取來源 IP 等特徵，並即時查詢自建的 MISP 情資平台或外部 API。若命中已知黑名單，則直接丟棄封包，以降低後端 AI 運算負載。

2. 異常偵測模型：針對通過預過濾的未知流量，系統將提取其流量行為特徵，輸入至模型中。而該模型採用非監督式學習，僅學習正常流量的模式。當遭遇具有攻擊特徵的流量時，模型將產生高重構誤差（Reconstruction Error），藉此判定為異常。

3. 自動化回應模組：一旦偵測模型判定為惡意，系統將觸發回應控制器。該控制器負責兩項任務：一是透過 Linux

Netfilter/iptables 下發阻斷規則；二是將該惡意 IP 與攻擊特徵自動回寫至 MISP 資料庫，生成新的入侵指標（IoC），實現情資的動態更新。

為了完成此計畫，我們統整並歸納出以下幾項預計要進行的步驟及方法：

1 了解虛擬網路架構和封包傳遞、分析及偵測方式

1.1 研究虛擬網路架構。

1.2 研讀封包傳遞與分析方式。

1.3 研讀封包偵測方式。

2 了解情資整合與資安自動化回應

2.1 研究情資整合系統。

2.2 研究資安自動化回應系統。

3 虛擬環境建置

3.1 建置環境 A：攻擊者負責發送惡意流量。

3.2 建置環境 B：防禦閘道負責檢測往返 A 與 C 的流量。

3.3 建置環境 C：受害伺服器。

4 資料生成與特徵工程

4.1 開發自動化 Python 腳本模擬正常流量 (用於模型訓練) 及攻擊流量 (僅用於模型測試與驗證)，並於環境 B 進行全流量側錄。

4.2 針對每個 QUIC 連線進行特徵提取，並對提取特徵進行資料標準化。

5 非監督式模型建構

5.1 利用 PyTorch 訓練模型，並實驗不同特徵輸入，找出最適合的比例。

6 情資整合與自動化回應

6.1 MISP 情資平台整合，當遇到新流量時於惡意清單中進行比對；並當防禦模型判定為惡意流量時，自動於 MISP 建立新事件，供後續分析。

6.2 SOAR 自動化回應，當情資平台或是模型發現為惡意流量，將依照預設腳本進行處理。

7 系統整合測試與評估

7.1 將模組進行整合，並測試、調整，已達到最適狀態。

8 研究成果報告撰寫

8.1 將實際運作狀況做紀錄，分析系統運作的穩定性，並將以上所有研究過程與我們的成果撰寫詳細的成果報告。

## (五) 預期結果

本計畫預期實現從流量偵測到阻斷回應的完全自動化。當模型偵測到異常時，系統能在無人工介入的情況下，於數秒內自動下發阻斷規則，並成功透過 API 將威脅指標 (IoC) 回寫至自建的 MISP 情資平台。預計之計畫時程請參閱表 1。

表 1、本計畫研究時程表

| 研究計畫時程表 | 115 年 7 月 | 115 年 8 月 | 115 年 9 月 | 115 年 10 月 | 115 年 11 月 | 115 年 12 月 | 116 年 1 月 | 116 年 2 月 |
|---|---|---|---|---|---|---|---|---|
| 了解虛擬網路架構和封包傳遞、分析及偵測方式 | | | | | | | | |
| 了解情資整合與資安自動化回應 | | | | | | | | |
| 虛擬環境建置 | | | | | | | | |
| 資料生成與特徵工程 | | | | | | | | |
| 非監督式模型建構 | | | | | | | | |

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| 情資整合與自動化回應 | | | | | | | | |
| 系統整合測試與評估 | | | | | | | | |
| 研究成果報告撰寫 | | | | | | | | |

## (六) 需要指導教授指導內容

1. 論文的寫作方式與思考邏輯。
2. 文獻的引用方式與格式。
3. 學術倫理。
4. 理論基礎：深度學習的模型、情資整合平台與 SOAR 的架構設計。
5. 成果報告撰寫。

## (七) 參考文獻


[1] W. Lim, K. S. C. Yong, B. T. Lau, and C. C. L. Tan. “Future of Generative Adversarial Networks (GAN) for Anomaly Detection in Network Security: A Review,” Computers & Security, vol. 139, Apr. 2024, Art. no. 103733. doi:10.1016/j.cose.2024.103733

[2] A. S. Iliyasu and H. Deng, “Semi-Supervised Encrypted Traffic Classification With Deep Convolutional Generative Adversarial Networks,” in IEEE Access, vol. 8, pp. 118-126, 2020, doi: 10.1109/ACCESS.2019.2962106

[3] J. Li, L. Zhou, H. Li, L. Yan and H. Zhu, "Dynamic Traffic Feature Camouflaging via Generative Adversarial Networks," 2019 IEEE Conference on Communications and Network Security (CNS), Washington, DC, USA, 2019, pp. 268-276, doi: 10.1109/CNS.2019.8802772.

[4] J. Luxemburk, K. Hynek and T. Čejka, "Encrypted traffic classification: the QUIC case," 2023 7th Network Traffic Measurement and Analysis Conference (TMA), Naples, Italy, 2023, pp. 1-10, doi: 10.23919/TMA58422.2023.10199052.